Modelle und Messbarkeit der Resilienz

Vorlesungsskript · Sitzung 2 · Grundlagen der Resilienz

Prof. Dr. Dirk Loomans

29. September 2026

Vorbemerkung: Dieses Skript dient als Vorlesungsbegleitung und erhebt keinen akademischen Anspruch. Dennoch kann es bei der Klausurvorbereitung hilfreich sein. Kommentare und Verbesserungsvorschläge gerne an den Autor über dirk.loomans@hs-mainz.de.

Die mit „Hinweis zur Aktualität“ und „Ergänzung zur Vorlesung“ markierten Kästen sowie die Abbildungen wurden bei der Überführung ins Quarto-Projekt ergänzt. Der übrige Text entspricht dem Skript aus dem Wintersemester 2025/26; korrigiert wurden nur Tipp- und Umbruchfehler.

1. Einleitung und Lernziele (Sitzung 2: Modelle & Messbarkeit der Resilienz)

Die vorangegangene Sitzung führte in den Begriff der Resilienz als Fähigkeit soziotechnischer Systeme ein, Störungen nicht nur zu überstehen, sondern nach Unterbrechungen funktionsfähig zurückzukehren und sich im Zeitverlauf anzupassen. In dieser zweiten Sitzung geht es um die Frage, wie diese Fähigkeit in der Praxis **modelliert, gemessen und bewertet** werden kann. Messbarkeit ist kein Selbstzweck, sondern Voraussetzung für Steuerung, Vergleich und Verbesserung — ein zentrales Prinzip sowohl der Ingenieurwissenschaften als auch des Cyber-Security-Managements.

Resilienz ist — im Unterschied zur reinen Prevention-Orientierung klassischer Security-Ansätze — **eine dynamische Systemleistung über die Zeit**. Diese zeitabhängige Perspektive findet sich beispielsweise explizit in der System Dynamics-Perspektive und im *Resilience Engineering* (vgl. Hollnagel/Woods/Leveson 2006), aber auch normativ in technischen Leitlinien wie der NIST-Spezifikation *SP 800-160 Vol. 2* zur Cyber-Resilience-Engineering-Praxis. Dort wird betont, dass Resilience nicht nur Widerstandsfähigkeit (*resist*), sondern ebenso die Fähigkeit zur Wiederherstellung (*recover*), Rekonstitution (*re-constitute*) und Anpassung (*adapt*) umfasst (vgl. NIST SP 800-160 Vol. 2).

Die Notwendigkeit, Resilienz zu messen, ergibt sich aus drei Gründen:

1. **Governance und Management-Steuerung** — Führung braucht belastbare Metriken zur Priorisierung, Budgetierung und Wirksamkeitskontrolle (vgl. ISO/IEC 27031; BSI-200-4).
2. **Vergleichbarkeit und Reifegradbewertung** — Reifegradmodelle ermöglichen es, Fortschritt und Gaps systematisch zu beurteilen (z. B. BCM-Reife nach BSI-200-4).
3. **Nachweisfähigkeit gegenüber Stakeholdern** — insbesondere in regulierten Domänen (KRITIS, Finanzmarktaufsicht) besteht Erwartung auf quantifizierbare Belastbarkeit.

In dieser Sitzung kombinieren wir zwei Perspektiven: (1) **quantitative Resilienzmetriken** (z. B. RTO, RPO, MTTR, MTBF, Service-Level-Degradationskurven) und (2) **modellbasierte Methoden und Referenzrahmen** (z. B. NIST SP 800-160 Vol. 2, ISO/IEC 27031, BSI-200-4-Reifegrade, ENISA-Orientierungen für sektorale Resilienz).

Lernziele dieser Sitzung: Nach dieser Sitzung können Studierende

- erklären, warum Resilienz quantitativ und qualitativ messbar gemacht werden muss;
- zentrale Resilienzkennzahlen für IT-Systeme (RTO, RPO, MTTR, MTBF) definieren und einordnen;
- Resilience-Modelle in Normen und Rahmenwerken korrekt verorten (NIST, ISO, BSI, ENISA);
- anhand einer Degradations-/Recovery-Kurve die Resilienz eines Systems qualitativ beschreiben;
- erste Reifegrad- und KPI-basierte Bewertungen realer IT-Systeme vornehmen.

2. Resilienz als Systemfunktion: Modellierung von Degradation und Wiederherstellung

Resilienz ist – im Gegensatz zu vielen klassischen Security-Metriken – **keine statische Eigenschaft**, sondern eine zeitabhängige Systemleistung. Ein IT-System ist nicht resilient oder nicht-resilient, sondern es zeigt ein bestimmtes **Verhalten unter Störung**. Die gebräuchlichste Darstellung ist die sogenannte **Degradations- und Wiederherstellungskurve**, welche die Systemleistung L(t) über die Zeit beschreibt.

Typischer Verlauf:

- **Phase 1 — Normalbetrieb**: L(t) ≈ 100 %
- **Phase 2 — Störung / Angriff / Fehler**: abrupte oder schleichende Abnahme der Leistung
- **Phase 3 — degradierter Zustand**: reduzierter Servicelevel oder Totalausfall
- **Phase 4 — Wiederherstellung (Recovery)**: schrittweiser oder sprunghafter Wiederanstieg
- **Phase 5 — Rückkehr in Zielzustand** (ggf. auf altem oder verbessertem Niveau)

Die charakteristischen Messgrößen ergeben sich direkt aus dieser Kurve:

- **Ausfalltiefe (Δ)** — Wie weit sinkt der Servicelevel im Worst-Case ab?
- **Wiederherstellungszeit (tR)** — Wie lange dauert es bis zum akzeptablen Servicelevel?
- **Datenverlustfenster (RPO)** — Welche Zeitspanne an Daten geht verloren?
- **Zieldauer (RTO)** — Innerhalb welcher Zeit *muss* der Dienst wiederhergestellt sein?

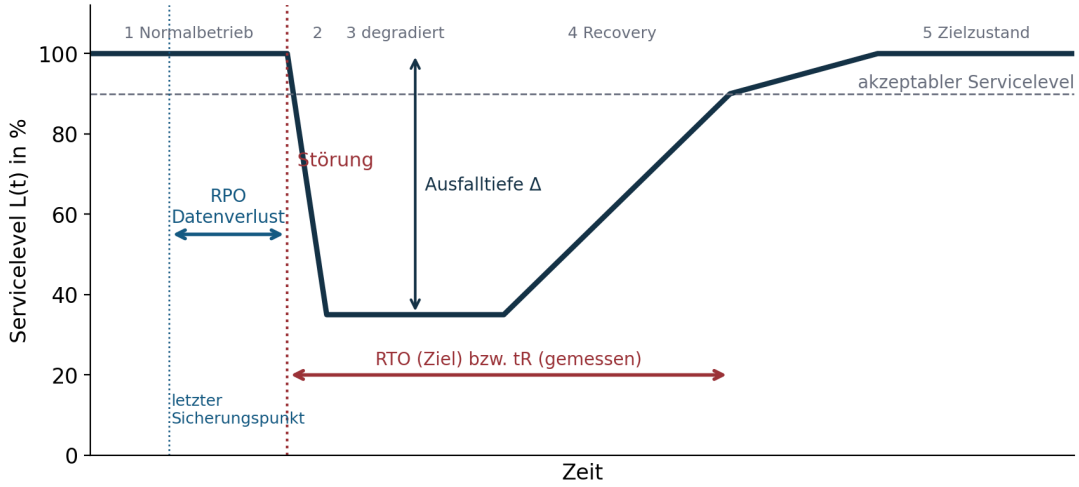


Abbildung 1: Schematische Degradations- und Wiederherstellungskurve mit RPO, RTO und Ausfalltiefe Δ

Diese Größen sind in Normen institutionalisiert (vgl. ISO/IEC 27031; BSI-200-4) und werden als Grundlage für Zielvereinbarungen und Architekturentscheidungen verwendet. Die amerikanische Cy-

ber-Resilience-Norm *NIST SP 800-160 Vol. 2* betont, dass Resilience Engineering primär die **Gestalt der Kurve unter Störung** adressiert, nicht den störungsfreien Idealzustand. Mit anderen Worten: **Resilienz zeigt sich nicht im Normalbetrieb, sondern in der Auslenkung.**

Der Vorteil dieses funktionalen Ansatzes liegt darin, dass er **technische, organisatorische und menschliche Maßnahmen vergleichbar macht**: Ob eine Wiederherstellung durch Backup, durch Umschaltung, durch Redundanz oder durch manuelle Notfallprozesse erfolgt – die Kurve misst das Ergebnis, nicht den Weg.

3. Quantitative Messgrößen der Resilienz (RTO, RPO, MTTR, MTBF)

Die Messung von Resilienz in IT-Systemen erfolgt häufig über Kennzahlen, die ursprünglich aus Zuverlässigkeitstechnik und IT-Betriebsmanagement stammen, aber in normative Kontexte eingebettet wurden (vgl. ISO/IEC 27031; NIST SP 800-160 Vol. 2).

(1) RTO — Recovery Time Objective

Zeitspanne, innerhalb der ein Dienst nach einer Störung wieder auf ein akzeptables Funktionsniveau gebracht werden *muss*. → „Wie lange dürfen wir realistisch offline sein?“

(2) RPO — Recovery Point Objective

Maximal tolerierbarer Datenverlust *in Zeit* (z. B. 15 min, 4 h). → „Wie alt dürfen die Daten maximal sein, die wir nach Recovery wiederherstellen?“

(3) MTTR — Mean Time To Repair

Durchschnittliche Dauer zur Wiederherstellung eines Systems nach Störung. → empirischer Wert, während RTO **ein Zielwert** ist.

(4) MTBF — Mean Time Between Failures

Mittlere Zeit zwischen zwei Ausfällen.

→ Maß für Zuverlässigkeit, nicht für Resilienz — aber entscheidender Parameter für Risikoexposition.

Table 1 Unterschied Ziel vs. Messwert

Kennzahl	Typ	Funktion
RTO / RPO	Planungsziel	normative/vertragliche Anforderung
MTTR / MTBF	Messwert	beobachtete Realwelt-Performance

In der Praxis ist Resilienz *kein* Maximum-Minimierungsproblem, sondern eine **Optimierung unter Nebenbedingungen** (Kosten, Regulatorik, Kritikalität). Normen wie ISO/IEC 27031 oder BSI-200-4 fordern deshalb die **Angemessenheit** („appropriateness“) — nicht absolute Minimierung.

Zusammenhang zur Resilienzkurve

- RTO entspricht dem Zeitpunkt, an dem die Kurve wieder den akzeptablen Servicelevel schneidet.
- RPO definiert den horizontalen Datenverlustbereich vor dem Wiederanlauf.
- Δ (Ausfalltiefe) und tR (Wiederherstellungszeit) beeinflussen die operative Wirksamkeit.

NIST SP 800-160 Vol. 2 argumentiert in diesem Kontext, dass Resilience Engineering messbare Eigenschaften *unvollkommener Systeme* adressiert — nicht die Abwesenheit von Fehlern, sondern den Umgang damit.

Ergänzung zur Vorlesung: Verfügbarkeit

MTBF und MTTR lassen sich zur **Verfügbarkeit** verbinden: A = MTBF ÷ (MTBF + MTTR). Mit MTBF = 30 Tage und MTTR = 45 min ergibt sich A ≈ 99,9 %.

Verfügbarkeit	Ausfall pro Jahr
99 %	ca. 3,7 Tage
99,9 %	ca. 8,8 Stunden
99,99 %	ca. 53 Minuten
99,999 %	ca. 5 Minuten

Es gibt zwei Hebel: seltener ausfallen (MTBF erhöhen) oder schneller zurückkommen (MTTR senken). Resilienz setzt vor allem am zweiten Hebel an. Die Verfügbarkeit sagt allerdings nichts über Datenverlust (RPO) und Ausfalltiefe (Δ) aus: Dieselbe Verfügbarkeit kann aus einem langen oder aus vielen kurzen Ausfällen entstehen.

4. Resilienzmodelle in Frameworks (NIST · ISO/IEC 27031 · BSI-200-4 · ENISA)

Während die zuvor beschriebenen Metriken (RTO, RPO, MTTR, MTBF) den **operativen Messaspekt** fokussieren, liefern Frameworks und Normen **strukturelle Modelle**, um Resilience Engineering verlässlich umzusetzen und zu bewerten.

4.1 NIST SP 800-160 Vol. 2 — Cyber Resilience Engineering

Das NIST-Modell beschreibt Resilienz als Menge koordinierter Fähigkeiten, die über den Lebenszyklus eines Systems verteilt sind (vgl. NIST SP 800-160 Vol.2):

- **Resist** — Störungen/Angriffe begrenzen
- **Detect** — Abweichungen schnell erkennen
- **Respond** — Reaktion koordinieren und eskalieren
- **Recover** — Leistungsfähigkeit wiederherstellen
- **Re-constitute** — System rekonfigurieren/neu aufsetzen
- **Adapt** — aus Ereignissen lernen und verbessern

Charakteristisch ist die Integration in **Engineering- und Architekturprozesse**, nicht erst in den Betrieb.

Hinweis zur Aktualität

NIST SP 800-160 Vol. 2 Rev. 1 (2021) definiert Cyber-Resilienz über die Ziele *Anticipate, Withstand, Recover, Adapt* [1]. Die hier verwendeten Begriffe (resist, re-constitute u. a.) stammen aus älteren Fassungen bzw. der Terminologie der Lehrveranstaltung. Siehe Quellen, Hinweis 1.

4.2 ISO/IEC 27031 — ICT Readiness for Business Continuity

ISO/IEC 27031 ergänzt das Business-Continuity-Management um einen spezifischen Fokus auf IKT-Wiederanlauffähigkeit:

- Vorbereitung (Readiness)
- Wiederanlauf-Planung (Recovery Planning)

- Tests & Exercises
- Lessons Learned und Verbesserungszirkel

Der normative Schwerpunkt liegt auf **Nachweisbarkeit und Testbarkeit**, nicht allein auf Dokumentation.

> **i** Hinweis zur Aktualität
>
> ISO/IEC 27031 ist 2025 neu erschienen („Cybersecurity – Information and communication technology readiness for business continuity“) [2]. Siehe Quellen, Hinweis 2.

4.3 BSI-Standard 200-4 — BCM mit Reifegradmodell

Der BSI-Standard 200-4 ordnet Resilienz in den Kontext von Business Continuity und nutzt **Reifegrade** als Bewertungsrahmen:

Reifegrad	Charakteristik
Ad hoc	Reaktion ereignisgetrieben, unkoordiniert
Initialisiert	Teilstrukturen vorhanden
Etabliert	Rollen, Pläne, Übungen integriert
Qualifiziert	Kennzahlen, Reviews, Lessons Learned
Exzellent	Optimierte, lernfähige Resilienzfähigkeit

Damit liefert der BSI-Standard einen **Bewertungsrahmen für Organisationen**, nicht nur Systeme.

> **i** Hinweis zur Aktualität
>
> Die finale Fassung des BSI-Standards 200-4 (Mai 2023) unterscheidet drei Stufen: Reaktiv-BCMS, Aufbau-BCMS und Standard-BCMS [3]. Die hier gezeigte fünfstufige Skala ist als allgemeines Reifegradmodell zu verstehen, nicht als Stufenmodell des Standards. Siehe Quellen, Hinweis 3.

> **i** Hinweis zur Aktualität: zwei Skalen in diesem Skript
>
> Dieses Skript nennt zwei fünfstufige Skalen: hier *Ad hoc – Initialisiert – Etabliert – Qualifiziert – Exzellent*, in Abschnitt 5.2 *Ad hoc – Definiert – Etabliert – Gesteuert – Optimiert*. Beide beschreiben dieselbe Entwicklungslogik. Folien und Lernseite verwenden einheitlich die Bezeichnungen aus Abschnitt 5.2.

4.4 ENISA — sektorale Resilienz & europäischer Kontext

ENISA-Publikationen adressieren insbesondere KRITIS-Sektoren (Energie, Gesundheit, Finanzmarkt, Transport) mit Best-Practice-Modellen für:

- sektorabhängige Bedrohungsmodelle
- Abhängigkeiten (Interdependencies)
- Response- & Recovery-Blueprints

Diese Orientierung ist vor allem relevant, wenn Resilienz **über Einzelsysteme hinaus** (z. B. Versorgungsketten, vernetzte Infrastrukturen) betrachtet wird.

Zwischenfazit:

Frameworks sind *keine Alternativen* zu Messgrößen, sondern liefern den **Ordnungsrahmen**, in dem Metriken geplant, bewertet und verbessert werden. Messgrößen erzeugen Evidenz — Frameworks verankern sie strukturell.

5. Reifegrad- und Bewertungsmodelle (Assessment aus technischer Sicht)

Die quantitative Messung von RTO/RPO etc. beantwortet die Frage: **„Wie verhält sich das System im Störfall?"**

Ein Reifegradmodell beantwortet eine andere Frage: **„Wie gut ist die Organisation vorbereitet, bevor der Störfall eintritt?"**

5.1 Zweck von Reifegradmodellen

Reifegradmodelle dienen nicht der Bewertung vergangener Leistungen, sondern der Steuerung zukünftiger Fähigkeit. Sie sind damit ein Governance-Instrument und wirken präventiv — aber mit direktem Einfluss auf Resilienz.

5.2 Strukturtypik

Die meisten Reifegradmodelle — unabhängig vom Standard — folgen einem ähnlichen Entwicklungspfad:

1. **Ad hoc** — keine Standardisierung, reaktive Einzelaktionen
2. **Definiert** — Prozesse existieren, aber wirken noch nicht zuverlässig
3. **Etabliert** — Rollen, Tests, Nachweise, KPIs verankert
4. **Gesteuert** — Messgrößen werden aktiv genutzt, Lessons-Learned etabliert
5. **Optimiert** — kontinuierliche Verbesserung & Resilience-by-Design

Diese Logik findet sich explizit z. B. in BSI-Standard 200-4 (vgl. BSI-200-4 Reifegradmodell) und implizit in ISO/IEC 27031 (Kapitel zu Testing & Improvement).

5.3 Verbindung zu Metriken

Reifegradfragen lassen sich direkt mit Metriken koppeln. Beispiele:

- **RTO-Ziel existiert → aber Recovery-Test nie durchgeführt = geringer Reifegrad trotz Kennzahl**
- **MTTR sinkt über Zeit → Hinweis auf lernende, adaptiv reagierende Organisation**
- **RPO definiert + Backups getestet → Evidenz statt reine Policy**

Ein hoher Reifegrad ohne gemessene Recovery ist **Papiersicherheit**; gemessene MTTR ohne organisatorischen Rahmen ist **Zufallssicherheit**. Resilienz verlangt **beides**.

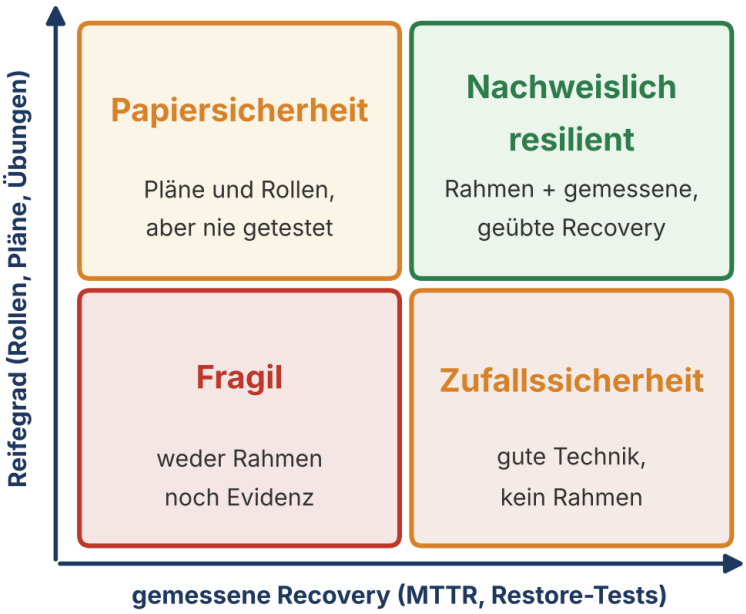


Abbildung 2: Reifegrad und gemessene Recovery: Papiersicherheit, Zufallssicherheit und nachweisliche Resilienz

6. Fallbeispiele und Analyse realer Degradationsverläufe

Die abstrakte Resilienzkurve gewinnt an Wert, wenn sie an realen Ereignissen überprüft wird. Reale IT-Störungen zeigen typische Muster von Degradation und Recovery, aus denen sich Resilienzfähigkeit rückwärts „ablesen" lässt.

Fall 1 — Ransomware in einer Kommunalverwaltung

- **Verlauf:** Totalausfall von Fachverfahren und E-Mail → mehrtägiger Betrieb im Notmodus
- **Recovery:** Wiederanlauf nur aus Offline-Backups (mehrere Tage RTO, hoher RPO-Verlust)
- **Analyse:** Technisch fehlten Segmentierung und getestete Recovery-Pfade; organisatorisch geringe Reife (kein getesteter BC-Plan) → Beispiel für **niedrige organisatorische und technische Resilienz trotz vorhandener Backups**

Fall 2 — AWS-Region-Ausfall (2021)

- **Verlauf:** Dienste in einer Region nicht erreichbar; Kunden mit Single-Region-Design vollständig offline
- **Recovery:** Multi-Region-Kunden blieben verfügbar oder konnten schwenken (Failover < Minuten)
- **Analyse:** Resilienz hing weniger am Provider als am Architekturmuster des Kunden
  - → **Architektur, nicht Plattform, entscheidet über Resilienz**

Fall 3 — Cloud-Gaming-DDoS mit degradierter Nutzbarkeit

- **Verlauf:** Service verlangsamt statt vollständiger Ausfall (Rate-Limiting, Warteschlangen)
- **Recovery:** Lastverteilung + Auto-Scaling → Rückkehr zu stabilem Niveau
- **Analyse:** Kein binärer Ausfall, sondern „Graceful Degradation" → Erhöhung der Resilienz-Wahrnehmung

- → Beispiel für **Adaptivität statt Hard-Fail**

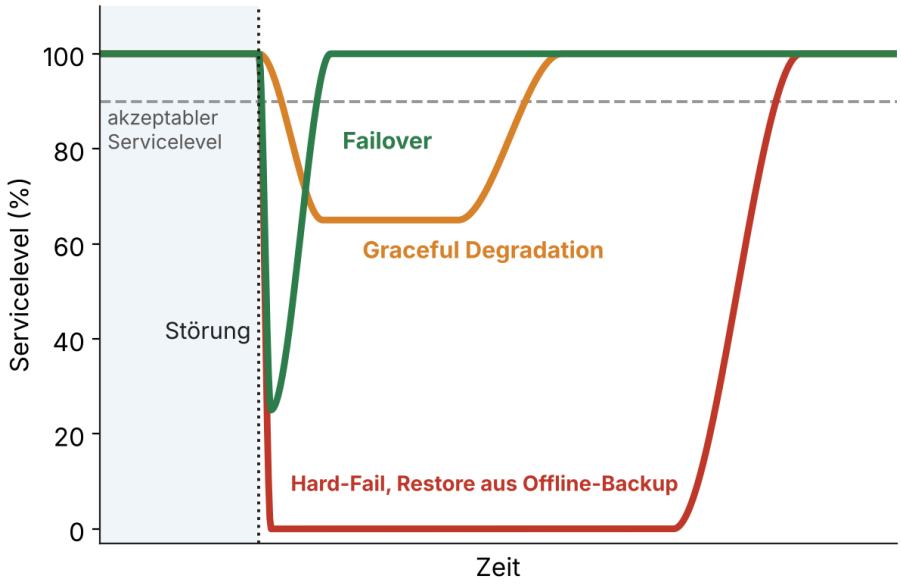


Abbildung 3: Dieselbe Störung, drei Architekturen: Hard-Fail, Failover und Graceful Degradation

Ergänzung zur Vorlesung: dokumentierte Vorfälle

AWS us-east-1 (7. Dezember 2021): Eine automatisierte Skalierung überlastete das interne AWS-Netz. Es war rund 7 Stunden gestört, einzelne Dienste bis zu 11 Stunden. Laufende Instanzen arbeiteten weiter, neue starteten nicht; auch Monitoring und Statusseite waren beeinträchtigt. Das konkretisiert Fall 2: Wer erst im Ernstfall Kapazität hochfahren wollte, stand still, und gerade im Störfall fehlten Messwerte.

OVHcloud, Straßburg (10. März 2021): Das Rechenzentrum SBG2 brannte aus, SBG1 wurde beschädigt. Kunden, deren Backup im selben Gebäude lag wie die Produktion, verloren beides – das RPO war faktisch unbegrenzt. 2023 sprach ein französisches Handelsgericht zwei Kunden Schadensersatz zu, weil die Sicherungen nicht wie vereinbart getrennt lagen.

GitLab.com (31. Januar 2017): Ein Administrator löschte versehentlich rund 300 GB auf der Produktionsdatenbank. Drei von vier Sicherungswegen hatten unbemerkt versagt; gerettet hat ein zufällig sechs Stunden alter Snapshot. Ergebnis: etwa 6 Stunden Datenverlust und rund 18 Stunden Ausfall. Laut Postmortem war niemand für die Backups verantwortlich und niemand testete sie – das tatsächliche RPO zeigt erst der Restore.

Quellenangaben unter Quellen.

Didaktische Quintessenz: Resilienz bewertet nicht, *ob* ein Ereignis eintritt — sondern *wie ein System danach aussieht*. Zwei Organisationen mit identischem Ereignis können vollständig unterschiedlich resilient wirken, je nach Architektur, Reifegrad und Recovery-Praxis.

7. Übungsauftrag: Bewertung eines IT-Systems anhand von Metriken & Reifegrad

Die Übung zielt darauf ab, die zuvor eingeführten Konzepte (Metriken, Framework-Logik, Reifegrad) auf ein **konkretes, real existierendes System** anzuwenden. Der Fokus liegt nicht auf technischer Tiefenanalyse, sondern auf der **argumentativen Bewertung von Resilienzfähigkeit**.

Aufgabenstellung (Gruppenarbeit, 20–30 Minuten)

Wählen Sie ein reales, allen bekanntes IT-System, z. B.:

- Uni-E-Mail
- Cloud-Speicher (OneDrive, Google Drive, Dropbox)
- Banking-App
- Cloud-Gaming-Dienst
- Krankenhaus-IT / Verwaltungssystem
- Smart-Home-Plattform

Analysieren Sie das System entlang der folgenden Leitfragen:

1. **Metriken realistisch schätzen**
   - Welches RTO wäre für dieses System angemessen?
   - Welcher RPO wäre tolerierbar?
   - Ist MTTR empirisch erkennbar (z. B. aus Statusseiten, öffentlichen Incidents)?
2. **Reifegrad qualitativ bewerten**
   - Ist das System ad-hoc oder professionell vorbereitet?
   - Gibt es Hinweise auf Übungen/Proben (z. B. Chaos-Engineering, DR-Tests)?
   - Gibt es Diversität/Redundanz oder Single Points of Failure?
3. **Kurzfazit argumentieren**
   - Ist das System heute eher **resilient**, **bedingt resilient** oder **fragil** — und warum?

Ergebnistyp 1–2 Slides oder ein strukturiertes Kurzstatement (max. 5 Stichpunkte pro Dimension).

Ziel der Übung ist nicht, perfekte Fakten zu recherchieren, sondern:

- das Denken in Resilienzmetriken zu trainieren,
- den Unterschied zwischen *gefühlt sicher* und *nachweislich resilient* zu verstehen,
- und Resilienz als **Bewertungsdisziplin** zu verinnerlichen.

8. Zusammenfassung, Prüfungsrelevanz und Ausblick

In dieser Sitzung wurde Resilienz als **mess- und bewertbare Eigenschaft von IT-Systemen** verstanden. Während Security-Kontrollen primär Eintrittswahrscheinlichkeiten reduzieren, adressiert Resilience Engineering die **Leistungsfähigkeit nach Eintritt eines Störereignisses** (vgl. NIST SP 800-160 Vol.2). Die Messung erfolgt über zeit- und funktionsbezogene Kennzahlen wie RTO, RPO, MTTR und MTBF, die sich aus der Degradations- und Wiederherstellungskurve ableiten lassen. Strukturierende Frameworks (NIST, ISO/IEC 27031, BSI-200-4) liefern die Governance-Logik und ermöglichen Reifegradbewertung und Nachweisfähigkeit.

Kernbotschaften dieser Sitzung

- Resilienz zeigt sich **nicht im Normalbetrieb**, sondern im Verlauf der Störung und Wiederherstellung.
- RTO/RPO sind **Zielgrößen** — MTTR/MTBF sind **Messgrößen** — beide sind notwendig und komplementär.

- Frameworks (NIST/ISO/BSI) schaffen **Verbindlichkeit und Vergleichbarkeit**.
- Reifegradmodelle bewerten **Fähigkeit vor dem Ereignis**, nicht Performance nach dem Ereignis.
- Resilienz ist eine Eigenschaft von **Architektur + Organisation + Übung**, nicht von Technologie alleine.

Prüfungsrelevante Leitfragen

- Wie unterscheidet sich Resilienzmessung von klassischer Sicherheitsbewertung?
- Erklären Sie RTO und RPO und ordnen Sie deren Funktion im BCM-Kontext ein.
- Wie verortet NIST SP 800-160 Vol.2 Resilience Engineering im Lifecycle?
- Welchen Zweck erfüllen Reifegradmodelle wie im BSI-200-4?
- Warum ist Recovery-Übung eine notwendige Bedingung für Resilienz?

Ausblick auf Teil 3 In der nächsten Sitzung werden wir die Resilienz **nicht mehr abstrakt**, sondern **konkret technisch verorten**:

Redundanz, Diversität, Wiederherstellbarkeit und Adaptivität — in hybrid verteilten Systemen (On-Prem + Cloud).

Damit schlägt Sitzung 3 die Brücke von den **Mess- und Modellkonzepten** (Sitzung 2) zur **architektonischen Umsetzung**.

Bibliografie

[1] R. Ross, V. Pillitteri, R. Graubart, D. Bodeau, und R. McQuaid, „Developing Cyber-Resilient Systems: A Systems Security Engineering Approach“, NIST Special Publication 800-160 Vol. 2 Rev. 1, Dez. 2021. doi: 10.6028/NIST.SP.800-160v2r1.

[2] „ISO/IEC 27031:2025 Cybersecurity – Information and communication technology readiness for business continuity“. [Online]. Verfügbar unter: https://www.iso.org/standard/27031

[3] „BSI-Standard 200-4: Business Continuity Management“. Bonn, Mai 2023.